Phase 7 | Security and Failure Analysis

Review trust boundaries and be prepared to explain concrete mitigations.

React/Vite Edition | Repository-grounded study material | Snapshot: 2026-10-24

1. Security review table

Area	Observed concern	Recommended direction
Browser token storage	AuthContext uses localStorage; OAuth callback includes token material in URL.	Use secure HttpOnly cookies or one-time code exchange; reduce token lifetime and avoid URL leakage.
JWT refresh	Refresh code decodes expired token payload before user lookup and reissue.	Use verified refresh tokens with revocation/rotation; do not trust decoded payloads alone.
Password and logs	Auth handlers log request or identity data; ensure credentials never reach logs.	Redact structured logs, rate-limit attempts and never log passwords, tokens or API keys.
OAuth	Callback and client credentials vary by environment; default Google-created role is student.	Validate identity claims and callback state; define safe account-linking and role assignment.
Uploads	Extension and MIME checks are present; size limits/content signature checks are not evident.	Add file-size limits, signature inspection, generated filenames and controlled storage.
Express sessions/CORS	Fallback session secret exists in code; allowed origins are configured.	Require production secret configuration and explicit trusted origins/cookie attributes.
Flask/Gemini	CORS is broad; debug mode is enabled in direct-run path; upstream call lacks explicit timeout.	Restrict origins, disable debug in production, add timeouts, rate limits and input bounds.
Geoapify	Backend key is required; provider rejection has been observed in the app.	Store only in server secret settings, verify correct key and restrictions, rotate exposed values.
Alert data	External content and timestamps may be malformed or stale.	Validate schema, escape content, preserve source/time and distinguish no alerts from feed failure.

2. Failure scenarios

Failure	Impact	Good behavior
MongoDB down	Account workflows and profile reads fail.	Report degraded health; return safe 5xx; do not pretend to persist.
OAuth misconfigured	Google sign-in callback fails.	Show clear setup error; retain password login if available.
Geoapify rejects key	Nearby search cannot refresh.	Show actionable error; use safe cached results only if freshness is clear.
NDMA feed unavailable	Alert ticker may be empty or stale.	Distinguish provider failure from “no active alerts.”
Gemini slow/blocked	Chat latency or no answer.	Timeout, sanitized error, retry UX and user input bounds.
Geolocation denied	Wrong or default map center may confuse.	Label fallback location and allow explicit location selection.

3. Safe logging checklist

- Log route, status, elapsed time, provider name and request ID.
- Never log passwords, Authorization headers, JWTs, OAuth codes, API keys or complete secret URLs.

- Avoid logging full user objects; minimize personally identifying information.
- Sanitize provider error bodies before returning them to the browser.
- Treat third-party alert titles/descriptions as untrusted text.

Ready Scout supports preparedness education. It must not be presented as a certified warning, dispatch, facility-availability or emergency-response system.